

Aula 4

Segurança da Informação

Prof. Patrick Landal Athayde

1

Princípios da comunicação segura

2

Introdução

- Pilar central para proteção de dados sensíveis
- Troca de informações em ambientes computacionais exposta a múltiplas ameaças
- Riscos à confidencialidade, integridade e autenticidade das mensagens
- *Malwares* como instrumentos recorrentes em ataques cibernéticos

3

Segurança da informação – conceitos fundamentais

- Informação como ativo de grande valor (Lyra, 2017)
- Proteção aplicável a
 - Sistemas computacionais
 - Informações eletrônicas
 - Sistemas de armazenamento físico ou digital
- Princípios essenciais: tríade CIA (confidencialidade, integridade, disponibilidade) + autenticidade, não repúdio e legalidade

4

Incidente de segurança

- Evento que compromete um ou mais princípios da segurança da informação
- Pode resultar em interrupção de atividades
 - Evento isolado
 - Série de eventos com impacto cumulativo
- Exemplos: ameaças, ataques, desastres naturais, greves, manifestações

5

Garantia de segurança

- Medidas para assegurar confiabilidade do ambiente de dados
- No desenvolvimento de software
 - Garantia deve ser perceptível e verificável pelo usuário
 - Testes auditáveis por laboratórios independentes

6

Modelos de ameaças e vetores de ataque

Modelos de ameaça

- **Definição:** possíveis ataques que podem ser executados sobre um sistema de informação
- **Importância**
 - Identificação de vulnerabilidades e pontos críticos
 - Apoio na criação de protocolos e sistemas de segurança mais eficazes
- Exemplos de modelos: STRIDE, PASTA, DREAD

Modelos de ameaça x vetores de ataque

- **Vetores de ataque**
 - Caminhos ou meios usados para explorar vulnerabilidades
 - Tipos
 - ✓ Vetores de rede
 - ✓ Vetores de aplicação
 - ✓ Vetores humanos
 - ✓ Vetores físicos

Modelo STRIDE (Isaacs, 2023)

- Acrônimo baseado em seis fatores de segurança
 - *Spoofing* – autenticidade
 - *Tampering* – integridade
 - *Repudiation* – não repúdio
 - *Information disclosure* – confidencialidade

- *Denial of service* – disponibilidade
- *Elevation of privilege* – autorização
- **Objetivo:** detectar fragilidades nesses quesitos para evitar violações e acessos indevidos

Modelo STRIDE

Quadro 1: Benefícios

BENEFÍCIOS	
Flexibilidade	STRIDE é uma estrutura adaptável e aplicável em diversos setores e contextos, não se restringindo a casos de uso específicos
Análise de possíveis falhas	Ajuda a responder à pergunta “O que pode dar errado?” do <i>framework</i> de <i>Shostack</i> , mapeando vetores e técnicas de ataque
Priorização de riscos	Permite ordenar ameaças e controles conforme sua criticidade, facilitando a gestão de riscos e recursos
Redução de violações	Quando corretamente aplicado, o STRIDE contribui para a prevenção de falhas e violações de segurança

Fonte: Elaborado com base em Addy (2023).

Modelo STRIDE

Quadro 2: Limitações do modelo STRIDE

LIMITAÇÕES	
Recurso intensivo	A aplicação completa do STRIDE em sistemas complexos demanda tempo e esforço considerável
Análise estática	O foco em arquitetura e design pode deixar de lado ameaças dinâmicas ou em tempo real
Subjetividade na avaliação	a análise de impacto e probabilidade pode variar conforme a equipe, tornando os resultados menos consistentes.
Manutenção contínua	O STRIDE requer revisões periódicas para refletir mudanças no sistema ou nas ameaças
Foco restrito a software	Foi originalmente concebido para desenvolvimento de <i>software</i> , o que limita sua aplicabilidade em domínios não digitais

Fonte: Elaborado com base em Addy (2023).

Modelo STRIDE

- **Necessidade de complementação**
- **Testes essenciais para identificar vulnerabilidades contextuais ou emergentes**
 - **Testes de penetração (*pentests*)**
 - **Auditorias de código-fonte**
 - **Validações em tempo de execução**

13

14

Modelo PASTA (*Process for Attack Simulation and Threat Analysis*)

- **Proposto por Tony UcedaVélez e Marco Morana (2015)**
- **Abordagem estruturada e interativa para**
 - **Identificar, analisar e mitigar ameaças cibernéticas**
 - **Unir perspectiva técnica e objetivos de negócio** (Addy, 2023)

Modelo PASTA

- **Sete etapas do PASTA** (Kirtley, 2022)
 - **Definição de objetivos**
 - **Definição de escopo técnico**
 - **Decomposição de aplicação**
 - **Análise de ameaças**
 - **Análise de vulnerabilidades e fraquezas**
 - **Modelagem de ataque**
 - **Análise de risco e impacto**

15

16

Modelo PASTA

- **Vantagens do PASTA**
 - **Estrutura sequencial e lógica facilita aplicação em ambientes complexos**
 - **Instruções claras para cada fase**
 - **Reduz complexidade ao dividir o problema em partes gerenciáveis**
 - **Enfoque simultâneo na avaliação técnica e no impacto nos objetivos do negócio**

Modelo DREAD

- **Desenvolvido pela Microsoft**
- **Metodologia de modelagem de ameaças para quantificar e priorizar riscos**
- **Aplicado a vulnerabilidades em sistemas de informação** (Meier et al., 2003; Microsoft, 2025)

17

18

Modelo DREAD

Quadro 3: Modelo DREAD

COMPONENTE	DESCRIÇÃO
Dano Potencial (damage potential)	Refere-se à gravidade do impacto causado pela exploração da vulnerabilidade, incluindo perdas financeiras, vazamentos de dados ou paralisação de serviços
Reprodutibilidade (reproducibility)	Mede o grau de facilidade com que o ataque pode ser repetido com sucesso por terceiros
Explorabilidade (exploitability)	Avalia o esforço, nível de conhecimento e recursos necessários para explorar a vulnerabilidade
Usuários afetados (affected users)	Considera a proporção de usuários impactados direta ou indiretamente pela exploração da ameaça
Descobribilidade (discoverability)	Indica a probabilidade de que a vulnerabilidade seja detectada por um atacante, considerando fatores como documentação, exposição e facilidade de análise

Fonte: Elaborado com base em Microsoft (2025).

Modelo DREAD

- Média aritmética das pontuações = índice de risco. Facilita
 - Avaliar severidade das ameaças
 - Decidir urgência de mitigação
 - Comparar sistematicamente diferentes ameaças
 - Alocar recursos de segurança de forma racional

19

20

Comparativo entre Modelos

Quadro 4: Comparativo entre modelos

Critério	STRIDE	PASTA	DREAD
Origem	Microsoft (Security Development Lifecycle - SDL)	Tony Uceda-Velaz e Marco M. Moussa (2012)	Microsoft (Usado originalmente com STRIDE)
A abordagem	Modelo qualitativo e categoriza de identificação de ameaças	Modelo estruturado em sete etapas, baseado em análise de risco e impacto no negócio	Modelo semiquantitativo de priorização de riscos com base em pontuações
Objetivo Principal	Identificar categorias de ameaças associadas a ativos e fluxos de dados	Realizar uma análise de ameaças centrada em riscos e contexto organizacional	Priorizar e classificar ameaças de acordo com critérios de impacto, frequência e impacto percebido
Componentes Centrais	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege	7 etapas (do entendimento do negócio à modelagem de ataques e mitigação de riscos)	Damage Potential, Reproducibility, Exploitability/Affected Users, Discoverability
Vantagens	Simple de aplicar, Ótimo para identificar vetores técnicos, Apoiado por diagramas	Abrange aspectos técnicos e de negócio, Baseado em risco e impacto, Método iterativo e detalhado	Permite quantificação do risco, Facilita a comunicação técnica/gestão, Apoiado decisões
Limitações	Foco técnico em software. Pouco voltado ao impacto de negócio, Não quantifica riscos	Processo mais complexo e demorado, Requer equipe multidisciplinar, Nem sempre é fácil de operacionalizar	Alta subjetividade nas pontuações, Pode simplificar cenários complexos, Menos replicável
Aplicabilidade	Análise técnica de sistemas de software e aplicações	Ambientes organizacionais complexos com múltiplos ativos e ativos críticos	Ambientes que exigem priorização rápida de falhas em sistemas já identificados
Relação entre os modelos	Pode ser usado como base para identificação de ameaças e serem detalhadas em PASTA ou priorizadas em DREAD	Pode incorporar resultados de STRIDE na etapa 4 (análise de ameaças) e usar DREAD para priorizar riscos identificados	Frequentemente utilizado como complemento ao STRIDE, para quantificar e ordenar ameaças

Fonte: Athayde (2023).

Vetores de ataque

- Definição: métodos utilizados por agentes maliciosos para comprometer sistemas e violar a confidencialidade, integridade e disponibilidade (Pronnus, 2023)
- Principais técnicas
 - Phishing
 - Malwares

21

22

- Exploração de vulnerabilidades
- Engenharia social
- Ataques a serviços (DNS, APIs, aplicações web) (Akamai, 2025)

Vetores de ataque

- Classificação
 - Ativos: provocam dano direto (ex.: ransomware)
 - Passivos: obtêm dados de forma furtiva (ex.: escutas, interceptação de tráfego) (Pereira, 2005)

23

24

- **Superfície de ataque**
 - Conjunto de pontos vulneráveis exploráveis
 - Inclui recursos físicos, digitais e fator humano
 - Quanto maior e mais exposta, maior a probabilidade de sucesso do ataque

25

Tipos de *malware* e ciclo de infecção

26

Malware: conceito e contexto

- **Cenário atual:** crescimento da infraestrutura digital → aumento das ameaças cibernéticas
- **Definição:** *malware (malicious software)* → código executável que compromete integridade, confidencialidade ou disponibilidade de sistemas
- **Alvos:** computadores pessoais, dispositivos móveis, redes, servidores corporativos

27

Tipos de *malware*

Quadro 5: Comparativo entre gerações de Malware

Parâmetro de comparação	Tradicional	Nova Geração
Nível de implementação	Codificação simples	Codificação complexa
Estados dos comportamentos	Estático	Dinâmica
Proliferação	Cada cópia é similar	Cada cópia é diferente
Forma de disseminação	Usa extensão .exe	Usa também diferentes extensões
Permanência no sistema	Temporária	Persistente
Interação com processos	Poucos processos	Múltiplos processos
Uso de técnicas de ocultação	Nenhum	Sim
Tipo de ataque	Geral	Direcionado
Desafio defensivo	Fácil	Difícil
Dispositivos-alvo	Computadores em geral	Muitos tipos de dispositivos

Fonte: Elaborado com base em Aelan e Samet (2020).

28

Etapas do ciclo de infecção (NIST SP 800-83 Rev.1; NIST SP 800-61 Rev.2)

- **Introdução no sistema-alvo**
 - Vetores escolhidos estrategicamente conforme superfície de ataque
 - Exemplo: instalação de *software* não autorizado (Ferreira; Araújo, 2008)
- **Execução**
 - Ativação e instalação autônoma

29

- **Persistência**
 - Alterações no sistema (registro, tarefas agendadas, elevação de privilégios)
 - Evasão de antivírus e *scanners* de integridade

30

Etapas do ciclo de infecção (NIST SP 800-83 Rev.1; NIST SP 800-61 Rev.2)

- Comunicação com servidores C&C (ISO/IEC 27002:2022)
 - Recebimento de instruções, furto de dados, atualização do *malware*
- Execução da carga útil
 - Criptografia de arquivos, espionagem, interceptação de dados, sabotagem

31

- Evasão e ocultação
 - Encriptação, mutação de código, camuflagem em processos legítimos
 - Uso de *packers* e *crypters*

32

Etapas do ciclo de infecção

- Conclusão
 - Processo multifásico, adaptativo e difícil de detectar
 - Requer controles alinhados às diretrizes normativas e práticas de segurança robustas

33

***Malware* como ferramenta de comprometimento**

34

***Malware* na era digital**

- Definição e relevância
 - Ferramenta central de agentes maliciosos para comprometer sistemas, redes e dados sensíveis
- Principais vetores de infecção
 - *E-mails phishing*

35

- *Downloads* falsos
- Vulnerabilidades de sistemas
- Dispositivos removíveis
- Engenharia social

36

Malware na era digital

- **Desafios para a defesa**
 - Sofisticação crescente das ameaças
 - Capacidade de camuflagem no ambiente infectado
 - Persistência e dificuldade de detecção

37

Tipos, técnicas e evolução do malware

- **Tipos Comuns de Malware** (NIST, 2013)
 - Vírus – dependem da ação do usuário para se propagar
 - *Worms* – autônomos, rápida disseminação
 - *Trojans* – disfarçados como *softwares* legítimos

38

- *Ransomwares* – sequestro de dados via criptografia
- *Spywares* – coleta furtiva de informações
- *Bots/botnets* – controle remoto para ataques em massa

39

Evolução do *malware*

- **Evolução do *malware***
 - Anos 1980: fins técnicos ou danos superficiais
 - Avanço da conectividade: propagandas maliciosas, ataques automatizados em massa
 - Última década: cibercrime organizado – lucro financeiro, espionagem, sabotagem

40

Prevenção e detecção de ameaças digitais

41

Contexto

- **Organizações cada vez mais dependentes de ambientes digitais**
- **Prevenção e detecção = pilares da integridade, confidencialidade e disponibilidade dos ativos**

42

- **Tecnologias de vigilância** (Moreira; Razzolini Filho; Adrião, 2023)
 - Geram informações relevantes sobre indivíduos
 - Criam relações entre pessoas e suas representações informacionais
 - Resultam de processos de agregação de dados

43

Detecção de ameaças

- **Detecção de ameaças**
 - Monitoramento contínuo de sistemas, redes, *endpoints* e aplicações
 - Identificação de comportamentos anômalos e riscos em tempo real
 - Possibilita investigação e resposta rápidas

44

Detecção de ameaças

- **Prevenção de ameaças**
- **Controles de acesso rigorosos**
- **Atualizações constantes de sistemas e aplicações**
- **Treinamentos de conscientização em segurança**

45

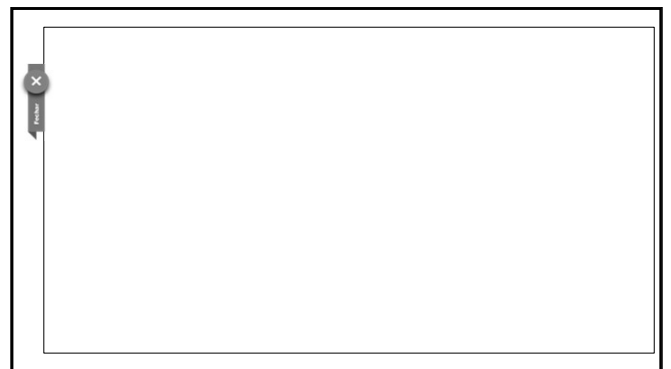
- **Tecnologias de proteção**
 - *Firewalls*
 - Antivírus
 - TDR/EDR (*Threat Detection and Response / Endpoint Detection and Response*)
 - Inteligência contra ameaças

46

Prevenção em segurança digital

- **Objetivo: proteger sistemas e dados contra acessos indevidos e ameaças**
- **Medidas-chave: políticas claras, avaliação de riscos, atualizações regulares, controle de acessos**
- **Ferramentas: antivírus, *firewalls*, IDS/IPS, monitoramento contínuo**

47



48